

Cybr2100 FinalPolicyMemo

Kettering Health Ransomware Incident (May 2025)

Executive Summary

On May 20, 2025, Kettering Health experienced a ransomware-driven system outage caused by unauthorized access to its network infrastructure, reportedly by the Interlock threat actor. The incident disrupted elective surgeries, inpatient and outpatient services, and the patient portal, requiring manual fallback procedures. There is also a possibility that patient data was exfiltrated, and the investigation remains ongoing.

The impact included delays in patient care, reputational damage, potential HIPAA violations, and financial disruption. To address these issues, I propose implementing a comprehensive Cybersecurity and Incident Governance Policy focused on strengthening access control, improving network segmentation, ensuring human oversight of automated systems, and establishing clear response and disclosure procedures.

Incident Analysis

Technical Factors

The incident likely resulted from weaknesses such as insufficient network segmentation, overly broad user privileges, gaps in monitoring or detection, or delayed patching. These vulnerabilities may have allowed attackers to gain access and move laterally across the network.

Legal Considerations

Kettering Health must comply with HIPAA requirements, including the Security Rule and Breach Notification Rule. These require protecting patient data and notifying affected individuals and regulatory bodies if protected health information is compromised.

Ethical Considerations

The organization has a responsibility to protect patient confidentiality, minimize harm caused by service disruptions, and maintain transparency with patients, staff, and regulators.

Ethical Framework and Policy Alignment

The response to this incident should follow key ethical principles:

- Proportionality: Security actions must match the level of risk without causing unnecessary disruption
 - Human oversight: Critical decisions, especially those affecting patient care, require human review
 - Privacy protection: Monitoring and response efforts must respect patient data and confidentiality
-

Governance and Roles

- Board and Executive Leadership: Approve and oversee cybersecurity governance policies
 - CIO and CISO: Lead response strategy, forensics, and containment decisions
 - Incident Response Team: Manage containment, investigation, and communication
 - Clinical Leadership: Ensure patient safety during system disruptions
 - External Partners: Provide forensic and legal support when needed
-

Incident Response Lifecycle

The response follows the NIST incident response framework:

1. Preparation: Establish policies, training, and backup systems
2. Detection and Analysis: Identify unauthorized activity and assess impact

3. Containment: Isolate affected systems to prevent spread
 4. Eradication: Remove malicious components and vulnerabilities
 5. Recovery: Restore systems and resume operations
 6. Post-Incident: Conduct reviews, audits, and improvements
-

Proposed Cybersecurity Policy

Access Control

Implement role-based access control, just-in-time privilege elevation, and mandatory multi-factor authentication for all critical systems.

Network Security

Adopt network segmentation and zero trust principles to limit lateral movement within the network.

Monitoring and Logging

Enable continuous monitoring and require human review of high-severity alerts. Retain logs for a minimum of three years.

Evidence Handling

Preserve logs and systems during incidents, maintain chain of custody, and restrict access to authorized investigators.

Disclosure and Notification

Establish clear procedures for internal escalation and external notification in compliance with HIPAA requirements.

Rules of Engagement

Define boundaries for response actions, require approval for critical system shutdowns, and prohibit offensive countermeasures.

AI and Automated Security Tools

Ensure transparency and explainability in automated systems, allow human override, and regularly evaluate system accuracy.

Healthcare-Specific Controls

Prioritize patient safety, enforce vendor security standards, maintain secure backups, and conduct regular disaster recovery testing.

Risk and Trade-offs

Implementing these controls involves balancing several factors:

- Security versus usability for staff
- Cost of implementation
- Privacy concerns related to monitoring
- System availability versus aggressive containment measures

These trade-offs must be carefully managed to maintain both security and patient care quality.

Implementation Timeline

- 0–1 Month: Enforce multi-factor authentication and begin vendor reviews
 - 2–3 Months: Deploy network segmentation
 - 4–6 Months: Introduce advanced monitoring tools and conduct response drills
 - 6–12 Months: Complete policy rollout and ongoing audits
-

Conclusion

The Kettering Health ransomware incident highlights the need for stronger cybersecurity governance and preparedness. The proposed policy addresses the root causes of the incident while aligning with legal, ethical, and operational requirements.

Adopting this policy will improve incident response capabilities, enhance system resilience, and better protect patient data and care delivery. Ongoing evaluation, training, and accountability will be essential to maintaining long-term effectiveness.